Digital Forensics and Biometrics
Notes on the acquisition of digital evidences

Simone Milani

A.A. 2023/2024

Copyright notice

All rights reserved. The educational material available on this platform is for the personal and exclusive use of the students and is covered by copyright. Any further use, in whole or in part, of the teaching material, including the reproduction, re-elaboration, diffusion and distribution of its contents by any means of communication, including technological platforms, software supports or telematic networks, is strictly prohibited, without express authorization by the author. Any improper use may rise in criminal and civil prosecution under the law of April 22, 1941, n. 633 and subsequent amendments (Protection of copyright and other rights related to its use).

1 International standards for the acquisition of digital evidences

The correct way of processing is defined by several internationally-agreed steps. While individual investigators, organizations and jurisdictions may well retain certain methods, processes and controls, it is hoped that standardization will (eventually) lead to the adoption of similar if not identical approaches internationally, making it easier to compare, combine and contrast the results of such investigations even when performed by different people or organisations and potentially across different jurisdictions. It doesn't matter whether you are from Italian police or English police: following pre-defined guidelines and protocols ensure that you have done a good job and the results of your activity can be used in a legal process.

Among these, it is worth of mention the ISO IEC 27037/2012 and other related standards (the so-called ISO27k family). The fundamental purpose of the ISO27k digital forensics standards is to promote good practice methods and processes for forensic capture and investigation of digital evidence.

ISO IEC 27037/2012 is an international standard defining guidelines for the identification, acquisiition and the preservation of digital evidences.

It has been created by the joint effort of two standardizing organizations:

ISO: International Organization for Standardization
ISO is a widely-reknown organization for the definition of technical guidelines. It is located in Geneva and cooperate with the IEC.

IEC: International Electrotechnical Commision IEC is more connected to the electrical and computer equipment. It is also located in Geneva, and basically represents a set of communities for the standardization.

In addition to ISO IEC 27037/2012, other standardization efforts can be strictly related to the acquisition and handling of forensic evidences.

ISO/TR 15801:2009	Document management - Information stored electronically – Recommendations for trustworthiness and reliability
ISO/IEC 17020:2012	Conformity assessment - Requirements for the operation of various types of bodies performing inspection
ISO/IEC 17025:2005	General requirements for the competence of testing and calibration laboratories
ISO/IEC 27000:2012	Information technology - Security techniques – Information security management systems - Overview and vocabulary
ISO/IEC 27041	Information technology – Security techniques – guidance for ensuring that methods and processes used in the investigation are "fit for purpose".
ISO/IEC 27042	Information technology – Security techniques – guidance on the analysis and interpretation of digital evidences w.r.t. continuity, validity, reproducibility, and repeatability.
ISO/IEC 27043	Information technology – Security techniques – guidelines based on idealized models for common incident investigation processes.

2 ISO IEC 27037/2012

ISO IEC 27037/2012 provides a detailed guide on the identification, collection and/or acquisition, labelling, storage, transport and preservation of digital evidences, particularly to maintain their integrity.

The standard was first published in 2012 and confirmed unchanged in 2018.

Indeed, the acquisition and preservation of the integrity are among the most critical issues in handling digital evidences during forensic investigations. Similarly to conventional physical evidence, the first and subsequent

responders need to maintain a clear and secure chain of custody of all digital forensic items ensuring that they are gathered and preserved through structured processes; such processes must grant the eligibility of the evidence in the legal process and be acceptable for a court. As a matter of fact, the issue is not only ensuring integrity but also assuring that nothing untoward have occurred.

Digital forensic evidence can come from any electronic storage or communications media such as cellphones, computers, iPod's, video game consoles etc. By its nature, digital forensic evidence is fragile - it can be easily damaged or altered due to improper handling, whether by accident or on purpose. As a consequence, most of the ISO IEC 27037/2012 best practices are primarily intended fr the the first responders.

From its very acquisition, the processing chain for a digital evidence can be summarized into four steps.

- **Identification (inspection)**
  In this phase, operators look at a situation and decide what item/file/record to acquire and how.

- **Seizure (virtual)**
  This activity corresponds to the physical acquisition of the support. to be analyzed or processed. As an example, let us assume that you find a digital camera which is supposed to contain a set of digital evidences (photos) useful for the investigations you are carrying on. Seizure activity includes all the operations that are enacted in order to bring the camera to the forensic lab.

- **Acquisition**
  It refers to the logical acquisition. of the evidence, i.e., all the operations that bring to the extraction of the file/disk sector/disk image that is supposed to be analyzed. Sometimes, acquisition can take place after the Identification phase whenever it is not possible to remove the physical digital support from its location.

- **Preservation (conservation and sealing)**
  This step concerns all the strategies and practices to keep the evidence safe during all the phases of its legal life. It defines the best solutions to prevent data alterations (e. g., keep hard drives in specific cases or storages), as well as authentication protocols that allows proving that the evidence is the original one.

Example: Garlasco's case: no forensic copy was performed.

Example: store DE in safe places or cases: no magnetic fields, no people around that can alter the evidence.

3 Contents of the ISO IEC 27037/2012standard

We have already anticipated that ISO IEC 27037/2012defines a set of protocols and procedures to handle digital evidences. But what are these practices that are presented in the document?

We can schematically summarized the contained information with the following list:

- **logging** (how to keep documentation for each phase of the analysis)
- **chain of custody** (practices to ensure traceability and integrity);
- **priorities** (in order to plan the investigation activity);
- **protection** (sealing and packaging of the devices);
- **transportation of evidences** (real/virtual - see the next sections);
- **roles in evidence exchanges** (who & why).

Beware that you will not find any information about:

- **legal issues** (national or international: these are depedning on the different legal systems)
- **analysis**
- **technical instruments**
- **report writing and presentation**
- **dealing with analogic data** (it focus on digital evidences).

4 Responders and actors for a digital evidence

Several figures operate around a digital evidence in relation to its acquisition, analysis and processing. We can generically divide them into first and subsequent responders, i.e., the operators that get in touch with the scene first and those that act at a second stage.

In this section, we will present the main ones.

4.1 Digital Evidence First Responder (DEFR)

he/sheis an operator that access digital evidence for the first time. In the case of the video from the Cyber CSI (see lecture recordings), the police officer that comes to the place first. he/sheis appointed by the central authorities and he/she must be experienced. he/shecan also use collaborators,

but basically, he/sheis the first one which is responsible for acquisition of the evidence.

What are the tasks of DEFR? We can summarized them in the following list:

- check and seizure the area containing digital devices e.g. cameras, video surveillance systems, computers, memory or storage devices;
- identify the person in charge for that area, e.g., in case of a computer room, personnel, network managers;
- keep people away from device and power supply (avoid they compromise the evidences, e.g., they shut down the device inadvertently);
- profile all the persons authorized to access the area (people working there or present in the place during the accident);
- avoid changing the state of devices (switching off a working device);
- document the scene, components, cables (pictures, video, drawings, schemes);
- identify notes, diaries, post-it, manuals (look for passwork and PINs).

In his/her activties, DEFR can interact with other operators which are presented in the following subsections.

4.2 Digital Evidence Specialist (DES)

he/sheis the one addressed as subsequent responder in the previous paragraphs. he/sheis an operator that is expert on the analysis of different evidences. Differently from DEFR, which is authorized and qualified to operate first on the crime scene to acquire and store digital evidences, DES can operate as a DEFR but has the competences to deal with a wide range of different technical issues (e.g., OS, network acquisitions, etc.).

4.3 IRS: incident response of specialists

This is the person that operates first after the fact, and therefore, it could be a person which is NOT in charge of the investigation.

As an example, let us suppose there is a cyber attack to a network of computer. The system manager (employed by the company that owns that computer network) reveals or basically detects the attack: he/sheis the first that operate on the place and could alter the evidences (or take some measures to protect them). he/sheis not in charge of the investigation.

4.4 FLM: Forensics Laboratory Managers (Operators)

he/sheoperates inside the forensics analysis lab, i.e., the lab guy that is going to analyze the evidence and get results. In order to access the digital evidence, he/sheis authorized by the competent authorities.

5 Digital Evidences: what are they and which requirements they must satisfy to be eligible

The term **Digital Evidence (DE)** can be related to all the devices, files, memory images or sectors, packet traces, images and videos that are to acquired and examined during a legal process in order to extract information that proves a certain statement or theory.

The information could be stored on different types of devices that need to be adequately identified and seized (when possible or appropriate).

Among the possible supports to be acquired as evidences, we can mention:

- memory devices inside computers (hard disks, floppy disks, optical disks, magentic/optical supports, USB pens, SD cards, etc.);
- cellphones, Personal Digital Assistants (PDAs), Personal Electronic Devices (PDEs), memory cards, GPS and navigation systems, smart home assistants (Alexa, Amazon Echo Dot, ...);
- photocameras and videocameras (including CCTVs)
- computers with network connections;
- robots (e.g. Roomba, etc.) or electronic devices with some processing power;
- network devices based on TCP/IP or other protocols;
- other devices related to the previous ones.

The acquisition and formatting process for a DE requires a good (solid when brought to court) procedure that must satisfy the following criteria.

Pertinence
DE must be useful in the legal process (e.g., to prove someone guilty or innocent). DE can not be acquired randomly or for no good as this could be subject to privacy regulations of the specific country where DEFR is operating.
To this extent, documentation must prove that the DE is relevant of worth

of acquisition.

Reliability
DEFR Ensure that the evidence is authentic (no alterations occurred during acquition or analysis).
Also in this case, all the processes and operations applied on the DE must be documented and reproducible.

Adequateness
To satisfy this requirement, DEFR must evaluate which/how much evidences must be acquired (and the methodologies to be adopted)
Indeed, several different sources can be copied or seized.
Sometimes, a complete copy is not possible or necessarily required (e.g., civil procedures).
This eventualities are strictly dependent on the case and on the national law systems, e.g., privacy regulations that are protecting other kind of data (not relevant for the investigation) contained in the memory support under acquisition.

Verificability
A third party should be able to verify the activities of DEFR and DES. This could be a layer or another forensic operator that need to perform some additional analysis.
This imply that DEFR and DES must provide some documentation on the scientific method, the techniques and procedures that has been adopted.
Indeed, DEFR and DES must be able to justify their operations.

Repeatability, Reproducibility
In order to verify the appropriateness and the validity of the analysis (and its conclusions), it could be useful to make the whole procedure repeatable as many times as desired. Operations and results can be replicated using the same method, procedures, tools, and conditions since all of these are precisey described and reported in the documentation.
Sometime, the same results/conclusions can be obtained/drawn using the same method, but different tools and conditions.

Provable
To this extent, DEFR and DES must prove that the adopted methods are the best possible for the task they were assigned.

In order to satisfy the previously-presented requirements, two main issues that affect the state of an evidence stored on a digital device need to be taken into account: *volatility* and *encryption*.

5.1 Volatility

Modern digital devices can be modelled like Turing machines: data and instructions are stored on some memory support.

Data and instructions are progressively loaded/stored and processed; but memory elements can be *volatile* or *non-volatile.*

Volatile memory is sometimes referred to as primary storage, as opposed to secondary storage (non-volatile), it is usually employed to store ready-to-be-processed information and it can be related to random access memory (RAM), main memory, processor's caches.

Non-Volatile memory is sually referred to solid-state drives (SSDs), hard disk drives (HDDs) or optical disks.

Data in volatile memory are not stable until you store them on non-volatile: if power goes off, data are lost. e.g. unplugging USB pen without ejecting the device.
The same problem applied in DE acquisition: if you power off the device or unplug it, it is possible that essential information goes lost (e.g. some IP address or important information about the attacker).
¡EXAMPLE¿

5.2 Encryption

Encryption can be assimilated to a way of scrambling data so that only authorized parties can understand the information by re-establishing the correct order.

The idea is to lock the information into digital boxes or formats that can be opened only by the possessors of a proper decryption key (see the example of the message in the locked box).

Similar to locking in a case the information; only those with the key can open it. It can be applied to disk/transmission in order to prevent unauthorized access: when accessed, data are decrypted and then re-encrypted again when saving/closing the file (or shutting down the program).

If you shut down the PC, the program is going to re-encrypt the data and you could not be able to access the data any more.

6 The different phases of ISO IEC 27037/2012

6.1 Preparation phase: Briefing

Before reaching the location of DE and proceed to its seizure/acquisition, DEFR need to organize the action and the activities.
This is possible by answering some questions that make possible to have a

preliminary idea of what scene he/sheis going to find and what issues are to be solved.

Simlarly to the classical Five Ws (or Six Ws in some of their definitions [1]) defined in journalism for information gathering or in problem solving, DEFR and DES would like to answer to the following interrogatives before getting on the scene:

1. What happened?
2. What should be looking for?
3. What do you expect to find?
4. What not?
5. How to ensure privacy and integrity of data? (define tools and method to preserve it).

In order to answer these questions properly, we need to:

- consider the type of incident;
- consider the time and date;
- examine the intervention plan;
- think about how DE is memorized and transported, i.e., preparing suitable materials for packaging.
- define specific tools for DE acquisition;
- evaluate the required instruments;
- remember to de-activate cable and wireless communications to/from the device;
- Give roles to the different subjects, which implies excluding people which are not authorized.

6.2 Identification

In this part, DEFR define what to acquire and how.

Every digital evidence has a physical and logical consistency. Moreover, several devices are usually available on a operating scene so that it is necessary to understand which devices have relevant data, whether they are in a critical state, and what are the best strategies/tools to acquire them.

As a matter of fact, it is necessary to chek a set of relevant properties/conditions and organize the different priorities (in order to minimize the possibility of losing data).

Indeed, DEFR should ask himdelf/herself if there are:

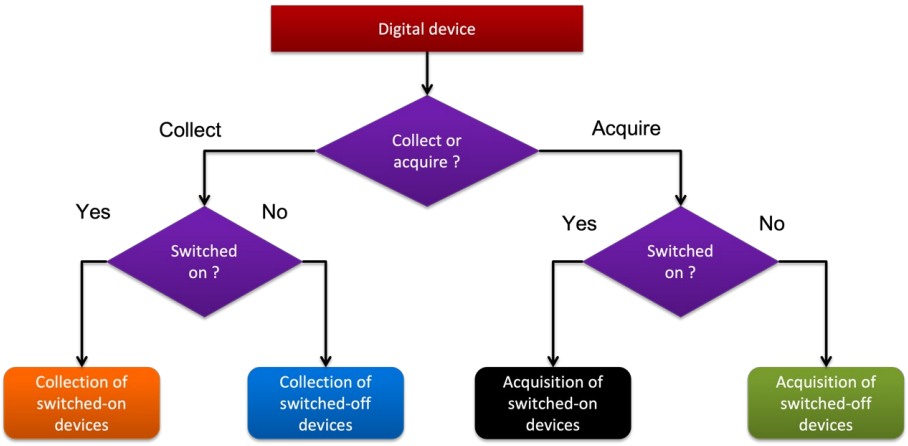


Figure 1: Identification of the proper acquisition strategy for DE.

- devices which presents volatile data
- devices difficult to localize/access
  - because of geography (e.g., cloud computing, SAN),
  - because of size (e.g., miniSD).

Note that a digital device (which receives, processes and stores data) can

- be connected to a network;
- have peripherals.

As an example, in case the device has a network interface, we must identify which terminals had exchanged data/communications with it (regardless of the fact that it is connected or not at the intervention time).

Therefore, DEFR must:

- document type, brand, s/n for each storage device;
- identify all the computers and peripherals, together with their state. If switched on, document what it is displayed (pictures, videos, description);
- collect power cables for each device using batteries;
- use a wireless signal detector to identify eventual systems that are present but not immediately visible;
- take into consideration possible non-digital evidences (e.g., referred by people).

Whithin this set-up, some issues needs to raise red-alert alarms to DEFR.

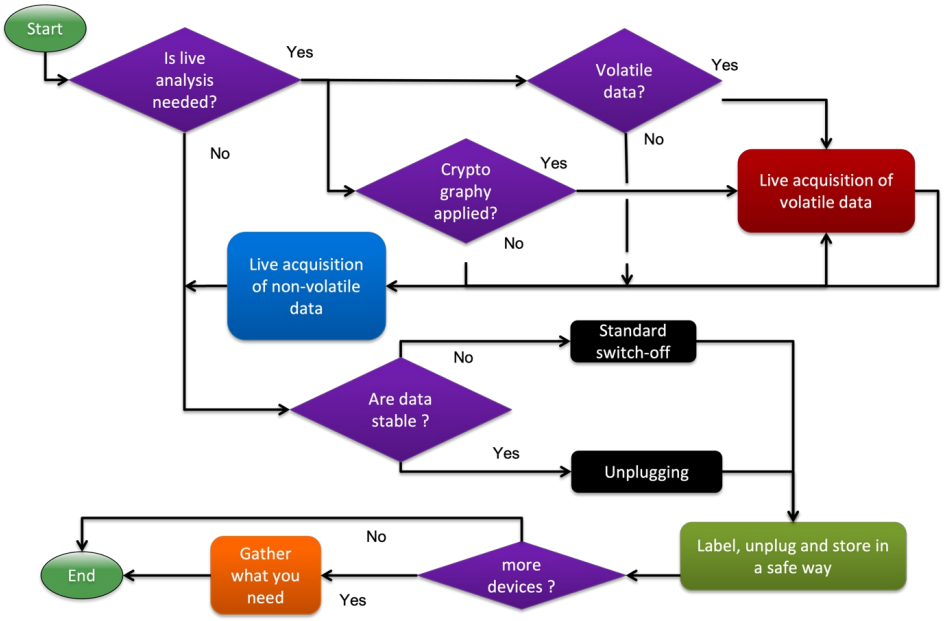


Figure 2: Collection of switched-on devices for DE acquisition.

Volatility i.e., the possible loss of important data

The use of cryptosystem on devices or on partitions that make Impossible to access the interested data.

The presence of critical elements for the systems, e.g. , an attack to a power plant, where you can not remove the PC without compromising the normal operativity.

Legal issues, e.g. , there is an attack to an hospital and you are basically wanted to acquire part of your disk of the hospital database, there can be privacy concerns since data of other patients (not related to the incident) could be present.

Resources, i.e., the availability of storage, time and personnel to acquire data, e.g. there is the risk that important information goes lost if the acquisition is not prompt: network attack where you need to analyze the attack stream while it is going on.

If is possible to schematize this process by means of the general diagram of Figure 1.

6.3 Collection or seizure

In this phase, the device is physically acquired by the legal operators. DEFR and DES must use the best practices based on costs and times (to be doc-

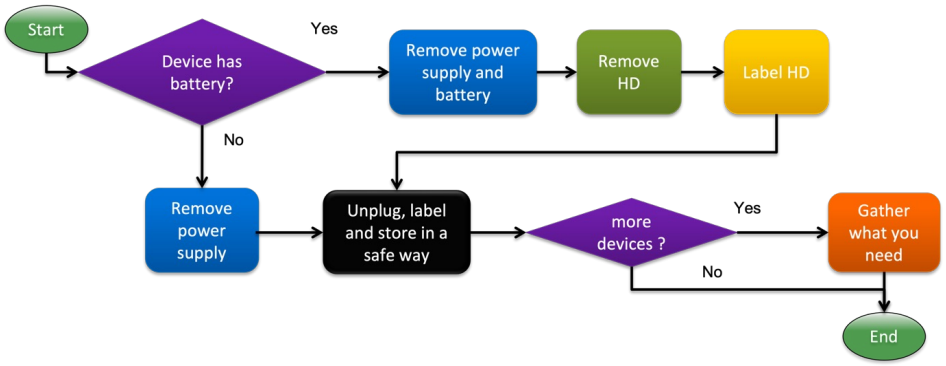


Figure 3: Collection of switched-off devices for DE acquisition.

umented in order to provide some eventual justification in court).

During this phase, we need to pay attention to the fact that devices can be switched on or off: this imply that switching off unproperly leads to the loss of volatile data.

Moreover, note that often accessories must be gathered as well inorder to keep the device working or enable data acquisition while in the lab (e.g., seize the cable to allow connecting the phone to the PC of the analyst).

It is possible to summarize a correct procedure with the following flow diagrams. More precisely, Figure 2 reports the flow of logical steps to be taken when acquired switched-on devices. Note that in this eventuality, the probability of losing data is very high because of volatility or encryption. After solving all the issues related to the switched-on state of the device, it is possible to proceed with a protocol that is very close to the one adopted for switched-off devices (see Fig. 3).

In alternative, Figure 3 reports the flow of logical steps to be taken when acquired switched-off devices. In this case, the pipeline flow is more linear and can be summarized by the following list.

1. verify that all devices are really switched-off;
2. remove memory storage from device (if not already);
3. Label memory device;
4. document details: type, vendor, s/n, part number, size;
5. acquire and compute hash value (for integrity verification).

7 Acquisition

During this phase, we refer to the logical acquisition of the data, i.e., the creation of a digital copy of the analyzed content.

Acquisition can be performed in two operative steps:

1. identify all the folders, files, their properties and relevant information that need to be acquired for the purposes of the investigation;
2. acquire the data by means of appropriate procedure and respecting the (eventual) data access restrictions (e.g., partial acquisition or complete seizure, see the following paragraphs).

Such activity can be performed after the device has been seized, but often, it can be necessary whenever the device can not be switched off for collection. This imply that acquisition activities can be divided into two main typologies:

Static, i.e., the device has been seized and therefore, data acquisition is safe since information has not been lost (or loss has already happened).

En-vivo or live, i.e., the device is switched on (and, eventually, active). Since it can not be switched-off and seized, acquisition must be performed on the spot and DEFR should avoid losing volatile data and be careful about encryption.

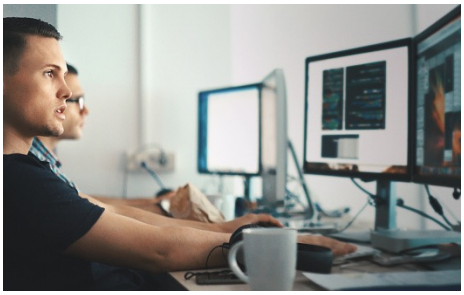
In addition to this first classification, it is possible to distinguish two additional acquisition typologies.

Complete acquisition: all the stored data are acquired.

Partial acquisition: only some files or sections of the hard disk are to acquired (often en-vivo directly on the scene).

Partial acquisition is usually required when:

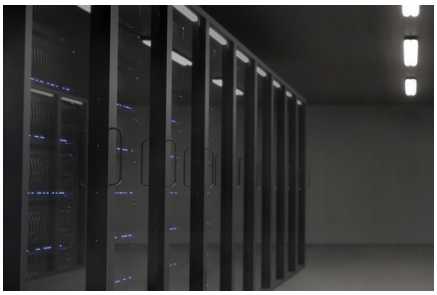
- the memory device, computer or system contains too many data, e.g., Google, DB servers, etc. (see Fig. **??**);
- you can not switch-off it and seize it, e.g., hospital, power plants, ... (see Fig. 7.1);
- only part of the data are relevant; therefore, you need to minimize the amount of information you need to handle (see Fig. 7.1);
- only part of the data can be acquired, e.g., there are legal issues, copyrights for some material, privacy restrictions if the system contains personal data of people not involved in the investigation (see Fig. 7.1).



(a)



(b)



(c)



(d)

Figure 4: Different acquisition scenes for a DE

7.1 Acquisition strategies

Considering live and static acquisition, we can mention 4 different data access methods:

1. **creating of a disk image file**: it implies a bit-by-bit copy of the hard drive
   Possible software or tools: ProDiscover, EnCase, FTK, X-ways, ILook, SMART, and Sleuth Kit

2. **disk-to-disk copy (cloning)**: it can be used when having a disk image file can not be copied because of errors
   Possible software or tools: EnCase, SafeBack.

3. **logical copy disk-to-disk or disk-to-file**: whenever the size of the drive/disk is prohibitive, logical copying comes to help. Typically, this typology is adopted when:

   - a partial acquisition is required;
   - the available amount of time is limited.

4. **copy of a single folder/file**: similar to logical copy by you acquire also erased data (unallocated).

Note: Cut & paste or Drag & drop are not forensic copies! You are missing erased files, slack space, free space; temporal data are lost.

So, what can be considered a **reliable forensic copy** of a disk? We can identify to main strategies: *disk cloning* or *bitwise copy* (which could be eventually available in compressed -lossless- format).

Disk cloning creates a functional one-to-one copy of a hard drive, while **disk imaging** creates an archive of a hard drive that can be used to make a one-to-one copy.

In general, the most widely strategy for data acquisition is **imaging**. Imaging is the the most widely-used forensic strategy in acquisition, i.e., creating a bit-stream copy of a disk or device in a non-invasive non-altering way; all the parts of the disk are copied (with meta-data). It allows a forensic copy of the acquired memory support: you can use it in court with no recusations (e.g., Garlasco's case)

Example 1: Online acquisition for defamating post.



A defamating post has been published on a social media platform. This post/image needs to be acquired for legal processes, but ...

- defamation is not a crime for the country hosting the server where images are stored;
- it can be removed anytime by the posting person;
- all storage can not be acquired;
- you need to operate with limited tools.

Solution: live acquisition with download or screenshots.

Authenticity could be questioned since malware, human errors and aterations can happen in the meantime. You must prove the integrity of environment and the network.

Possible strategies to prove that acquisition is authentic:

- using live OS (whose images is provided with the material);
- video record all the operations for documentation;

- before acquiring the image/post visit some website or run some network diagnostic software: it proves that you acquired the evidence on the actual web.
- use different softwares for hash computation.

Specific software: LegalEye.

8 Conservation

In this phase, DEFR and DES must adopt proper protocols to protect data from alterations (natural, on-purpose, damages, etc.).

Methodology must preserve data integrity and allows verifying that no alterations occurred.

Privacy must be protected as well; special packaging could be needed.

Example of preservation strategies: In order to protect acquired hard drive from external wireless connections (which could alter the satet of the data) , it is possible to use magnetic supports, i.e., anti-static cases.

For this activity, the following cautions must be payed.

- Data must adequately labelled;
- Verify that batteries are adequately charged (and re-charged), if present;
- Fix mobile parts;
- Minimize risks concerning the type of support;
- Minimize transportation risks;
- Preserve eventual additional traces (e.g., biological traces, fingerprints, ...).

8.1 Integrity verification

As anticipated before, images are widely accepted in courts, and usually more copies are created: there is going to be one master file and multiple replicas to be given to all the legal actors involved.

This procedure allows to distribute evidences for independent analysis and give the resource back to the owner. As a matter of fact, we need to have a procedure that allows verifying that no alterations have occurred.

In the verification of integrity for DE, we can use cryptographic and channel-coding strategies that generates a signature which results altered whenever some modifications occurred on the data stream.

Hash functions are procedures that permit generating a fixed length string that operates as a signature for the file. Whenever some bits are altered in the file f, the values of the string $\mathbf{d}$ change. Therefore, we can formalize a hash functions as

$$H : \text{file} \mapsto \{0,1\}^n$$

$$f \mapsto \mathbf{d}$$

Definitions:

- **digest**: string of symbols/bits with predefined length generated by a hash function operated on the bits of a file/image.
- **hash function**: non invertible function that maps variable length strings of symbols/bits into fixed length strings of bits.

Note that an hash function needs to satisfy some basic building properties:

- H is not mutual;
- from digests it is not possible to reconstruct files;
- it is very unlikely that two different files has the same digests (although probability is not null: *collisions*);
- it can be used to detect bit alterations.

The main properties can be formalized into three resilience definitions

Resilience to pre-image: given a digest d, creating a variable-length string f s.t. $\mathbf{d}(f) = \mathbf{d}$ must be computationally-unfeasible.

Resilience to second pre-image: given a digest $\mathbf{d}_1 = \mathbf{d}(f_1)$ computed on a variable-length string f_1, it must be computationally-unfeasible to find f_2 s.t. $\mathbf{d}_2 = \mathbf{d}(f_2) = \mathbf{d}_1$.

Resilience to collision: searching for a couple of strings f_1 and f_2 such that $\mathbf{d}(f_2) = \mathbf{d}(f_1)$ is computationally-unfeasible.

Possible hash functions:

Name	Document	Digest's length	Comments
MD5	RFC1321	128 bits	• fast; • widely diffused; • it is highly-improbable to find two different strings with the same MD5 hash.
SHA-x	NSA, NIST.	SHA-1 160 SHA-224 224 SHA-256 256 SHA-384 384 SHA-512 512.	• different lengths supported; • more robust than MD5.

Best practices imply using more than one since each algorithm is not completely safe for an attack.

Example 2: Toy example on hash computation.

Consider the sequence of numbers: 12, 34, 56, 78, 43, 45, 79, 81.

Suppose that the hash/signature is computed by summing all the numbers (getting 428) and taking the last digit (8).

Suppose that the third number (56) is altered into 57: in this case the sum is 429, and therefore, the resulting signature is 9.

the alteration is detected.

9 Chain of custody

The chain of custody defines the history of the service/support starting from the intervention moment. It can be created in the form of paper/digital documentation, and it must contain some crucial information about the evidence.

Usually, the chain of custody includes:

- the ID of the evidence;
- when, where, who and why accessed the evidence;
- the documentation and justification for every possible alteration (with the name of the person which is responsible for that).

This operation can be formatted into a sequence of steps.

- keep an evidence log showing when and where the evidence was received and seized; where it is located;
- record dates if items are released to anyone;
- restrict access to the evidence;
- place original hard drive to a locker;
- perform all forensics on a mirror copy.

10 Final considerations on presentation

Finally, all the operations and analysis must be written on a report and presented in court.

The report needs to present very well:

- What has been done;
- How it has been done;
- What kind of data have been obtained;
- What is the meaning/evidence brought by the obtained data.

Note also that the language and style must be adapted to the target audience, i.e., writing and presentation style could be:

Technical or

Jurisdictional.

Note that these guidelines are not contained in ISO IEC 27037/2012.

References

[1] G. Hart. The five w's of online help systems. *geoff-hart. com. Retrieved April*, 30, 2012. Accessed: 2023-08-10.